

Corporate Data Protection and GDPR Compliance Policy

Document Reference: DP-POL-2026-04 **Classification:** Internal — Confidential **Effective Date:** 1 March 2026 **Review Cycle:** Annual **Owner:** Office of the Data Protection Officer (DPO) **Applies To:** All employees, contractors, and third-party processors handling personal data on behalf of the Company

1. Purpose and Scope

This policy establishes the mandatory requirements for the collection, processing, storage, transfer, and deletion of personal data by the Company, in accordance with the General Data Protection Regulation (EU) 2016/679 ("GDPR") and applicable national implementing legislation. It applies to all business units, subsidiaries, and third-party vendors that process personal data on the Company's behalf, regardless of whether such processing occurs within the European Economic Area (EEA).

This policy does not apply to fully anonymized data from which no individual can reasonably be re-identified.

2. Definitions

2.1 Personal Data: Any information relating to an identified or identifiable natural person ("data subject"), including names, identification numbers, location data, online identifiers, or factors specific to physical, physiological, genetic, mental, economic, cultural, or social identity.

2.2 Special Category Data: Personal data revealing racial or ethnic origin, political opinions, religious beliefs, trade union membership, genetic data, biometric data used for identification, health data, or data concerning sex life or sexual orientation.

2.3 Processing: Any operation performed on personal data, including collection, recording, organization, structuring, storage, adaptation, retrieval, use, disclosure, or erasure.

2.4 Data Controller: The entity that determines the purposes and means of processing personal data.

2.5 Data Processor: The entity that processes personal data on behalf of the Data Controller.

2.6 Data Protection Impact Assessment (DPIA): A structured process to identify and minimize the data protection risks of a project or system.

3. Lawful Basis for Processing

3.1 All processing of personal data must rely on at least one of the following lawful bases under Article 6 GDPR:

(a) Consent of the data subject; (b) Necessity for the performance of a contract; (c) Compliance with a legal obligation; (d) Protection of vital interests; (e) Performance of a task carried out in the public interest; (f) Legitimate interests pursued by the Company, provided such interests are not overridden by the data subject's rights.

3.2 Where processing relies on consent, consent must be freely given, specific, informed, and unambiguous. Consent must be as easy to withdraw as it is to give.

3.3 Special Category Data may only be processed where an additional condition under Article 9 GDPR is satisfied, such as explicit consent or necessity for employment law obligations.

4. Data Minimization and Retention

4.1 Personal data collected must be adequate, relevant, and limited to what is necessary for the stated purpose of processing.

4.2 Retention periods must be defined for each category of personal data and documented in the Company's Record of Processing Activities (RoPA). Unless a longer period is required by law, the following default retention schedule applies:

Data Category	Default Retention Period
Employee HR records	6 years post-termination
Customer transaction records	7 years
Marketing consent records	3 years from last engagement
CCTV footage	30 days
Job applicant data (unsuccessful candidates)	12 months

4.3 At the expiry of the applicable retention period, personal data must be securely deleted or irreversibly anonymized within 30 calendar days.

5. Data Subject Rights

5.1 The Company must be able to respond to the following data subject rights requests within one calendar month of receipt, extendable by two further months for complex requests with notification to the data subject:

(a) Right of access (Article 15); (b) Right to rectification (Article 16); (c) Right to erasure / "right to be forgotten" (Article 17); (d) Right to restriction of processing (Article 18); (e) Right to data

portability (Article 20); (f) Right to object (Article 21); (g) Rights related to automated decision-making and profiling (Article 22).

5.2 All requests must be logged in the Data Subject Access Request (DSAR) register and routed to the DPO within 2 business days of receipt by any employee.

5.3 The Company shall not charge a fee for the first request unless the request is manifestly unfounded or excessive, in which case a reasonable administrative fee may apply or the request may be refused with justification provided to the data subject.

6. Data Breach Notification Procedure

6.1 Any employee who becomes aware of an actual or suspected personal data breach must report it to the DPO immediately, and in no case later than 4 hours after discovery.

6.2 Where a breach is likely to result in a risk to the rights and freedoms of natural persons, the DPO must notify the competent supervisory authority without undue delay, and in any case within 72 hours of becoming aware of the breach.

6.3 Where a breach is likely to result in a *high* risk to data subjects, affected individuals must be notified directly without undue delay, using clear and plain language describing the nature of the breach and the measures taken.

6.4 The Incident Response Team must maintain a Breach Register documenting: the nature of the breach, categories and approximate number of data subjects affected, likely consequences, and remedial measures taken.

7. International Data Transfers

7.1 Transfers of personal data outside the EEA are prohibited unless one of the following safeguards is in place:

(a) An adequacy decision issued by the European Commission for the destination country; (b) Standard Contractual Clauses (SCCs) approved by the European Commission; (c) Binding Corporate Rules (BCRs) approved by the competent supervisory authority; (d) An explicit derogation under Article 49 GDPR, applied only in exceptional and non-repetitive circumstances.

7.2 All cross-border data flows must be documented in the Company's Transfer Impact Assessment (TIA) register prior to transfer taking place.

8. Data Protection Impact Assessments (DPIA)

8.1 A DPIA is mandatory prior to processing that is likely to result in high risk, including:

(a) Systematic and extensive profiling with legal or similarly significant effects; (b) Large-scale processing of Special Category Data; (c) Systematic monitoring of publicly accessible areas on a large scale; (d) Deployment of new technologies with novel or high-risk processing characteristics.

8.2 The DPIA must assess the necessity and proportionality of the processing, identify risks to data subjects, and document mitigation measures. Residual high risks that cannot be mitigated must be referred to the supervisory authority for prior consultation.

9. Vendor and Third-Party Processor Management

9.1 No personal data may be shared with a third-party processor unless a Data Processing Agreement (DPA) compliant with Article 28 GDPR is executed prior to data transfer.

9.2 The DPA must specify: the subject matter and duration of processing, the nature and purpose of processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller.

9.3 Processors must not engage a sub-processor without prior specific or general written authorization of the Company, and any sub-processing arrangement must impose equivalent data protection obligations.

9.4 The Procurement function must maintain an approved vendor register indicating each vendor's data processing role, transfer mechanism (if applicable), and last audit date.

10. Roles and Responsibilities

10.1 **Data Protection Officer (DPO):** Monitors compliance, serves as the point of contact for supervisory authorities and data subjects, advises on DPIAs, and maintains the RoPA.

10.2 **Business Unit Owners:** Ensure processing activities within their function comply with this policy and cooperate with DPIA and audit requests.

10.3 **IT Security:** Implements technical measures including encryption at rest and in transit, access controls based on the principle of least privilege, and regular vulnerability assessments.

10.4 **All Employees:** Must complete mandatory annual data protection training and report any suspected breach or non-compliance immediately.

11. Enforcement and Sanctions

11.1 Non-compliance with this policy by an employee may result in disciplinary action up to and including termination of employment, in accordance with the Company's disciplinary procedure.

11.2 Non-compliance by a third-party processor constitutes a material breach of contract and may result in immediate termination of the processing agreement.

11.3 The Company acknowledges that regulatory non-compliance with GDPR may result in administrative fines of up to €20 million or 4% of total worldwide annual turnover, whichever is higher, in addition to reputational and operational harm.

12. Policy Review

This policy shall be reviewed at least annually by the DPO, or sooner in the event of material changes to applicable data protection legislation, business operations, or following a significant data breach.

13. Employee Monitoring and Workplace Privacy

13.1 The Company may conduct monitoring of corporate email, internet usage, and network activity strictly for the purposes of: (a) IT security and prevention of unauthorized access; (b) compliance with legal obligations; (c) prevention of harassment or misconduct in the workplace.

13.2 Monitoring must be proportionate and employees must be informed of the nature and extent of monitoring via the Employee Handbook prior to commencement of employment. Covert monitoring is prohibited except where authorized in writing by the DPO and Legal Counsel in connection with a specific, documented investigation into suspected serious misconduct.

13.3 CCTV surveillance on Company premises is limited to entrances, exits, and asset-security areas. Cameras must not be installed in areas where individuals have a reasonable expectation of privacy, including restrooms and break rooms.

13.4 Location tracking of Company-issued devices is permitted only for fleet and asset management purposes and must be disclosed to the employee at the point of device issuance.

14. Cookie and Online Tracking Policy

14.1 The Company's public-facing websites must display a cookie consent banner prior to setting any non-essential cookies, categorized as: Strictly Necessary, Performance, Functional, and Targeting/Advertising.

14.2 Strictly Necessary cookies may be set without consent. All other categories require opt-in consent, and users must be able to withdraw consent as easily as they granted it, accessible via a persistent "Cookie Preferences" control.

14.3 A record of consent (timestamp, IP address hash, consent string) must be retained for 12 months to demonstrate compliance in the event of a regulatory audit.

15. Children's Data

15.1 The Company's products and services are not directed at individuals under the age of 16. Where the Company becomes aware that it has inadvertently collected personal data from a child under 16 without appropriate parental consent, such data must be erased within 5 business days of discovery.

15.2 Age-verification mechanisms must be implemented on any registration flow where the target audience may reasonably include minors.

16. Frequently Asked Questions (Internal Reference)

Q1: Can I forward a customer's personal data to a colleague outside their business unit? Only if the recipient has a legitimate business need to access the data consistent with the original purpose of collection. When in doubt, consult the DPO before forwarding.

Q2: A former employee has requested a copy of their HR file. What do I do? Log the request in the DSAR register immediately and forward to the DPO within 2 business days. Do not respond directly or provide any data yourself.

Q3: Is it acceptable to store customer data on a personal laptop or USB drive? No. All personal data must remain within Company-approved, encrypted systems. Local or removable storage of personal data is prohibited absent a documented and approved exception.

Q4: We are launching a new mobile app that will collect location data. What is required? A DPIA must be completed and approved by the DPO before the feature is deployed, given that location data processing may qualify as high-risk under Section 8.1.

Q5: How long can we keep CVs of unsuccessful job applicants? 12 months from the date the recruitment decision is communicated, after which the data must be deleted unless the candidate has separately consented to inclusion in a talent pool.

Appendix A — Data Retention Schedule (Extended)

Data Category	Department	Retention Period	Legal Basis for Retention
Payroll records	Finance	7 years	Statutory tax/accounting obligation
Performance reviews	HR	3 years post-review	Legitimate interest
Whistleblowing reports	Legal/Compliance	5 years	Legal obligation
Supplier due diligence files	Procurement	5 years post-contract	Legitimate interest

Data Category	Department	Retention Period	Legal Basis for Retention
Website analytics (aggregated)	Marketing	26 months	Consent
Helpdesk support tickets	IT	2 years	Legitimate interest
Access control logs (badge swipes)	Facilities	90 days	Legitimate interest / security

Appendix B — Incident Report Template (Summary Fields)

1. Date and time of discovery
2. Name and role of reporting employee
3. Systems or data categories affected
4. Estimated number of data subjects impacted
5. Root cause (if known at time of report)
6. Immediate containment actions taken
7. Whether Special Category Data was involved (Y/N)
8. DPO notified (timestamp)
9. Supervisory authority notification required (Y/N) and deadline
10. Data subject notification required (Y/N) and rationale

Appendix C — DSAR Intake Checklist

- ☐ Confirm requester identity via approved verification method
- ☐ Log request date and channel (email, post, in-person)
- ☐ Determine applicable right(s) being exercised
- ☐ Identify all systems holding relevant personal data
- ☐ Assess for third-party data requiring redaction
- ☐ Prepare response within statutory deadline (1 month, extendable to 3)
- ☐ Obtain DPO sign-off prior to release
- ☐ Log completion date and method of delivery

Appendix D — Mandatory Training Requirements

Role	Training Module	Frequency
All employees	GDPR Fundamentals	Annual
Managers	Handling DSARs and Escalation	Annual
IT/Engineering	Privacy by Design and Secure Development	Annual
Customer Support	Identity Verification and Data Minimization	Bi-annual
New hires	Onboarding Data Protection Briefing	Within first 14 days

Appendix E — Approved Transfer Mechanisms by Destination Country (Illustrative)

Destination	Mechanism in Use	Last Reviewed
United States	Standard Contractual Clauses + supplementary encryption measures	Q1 2026
United Kingdom	UK Adequacy Regulations	Q4 2025
Japan	EU-Japan Adequacy Decision	Q3 2025
India	Standard Contractual Clauses	Q1 2026
Singapore	Standard Contractual Clauses	Q2 2025
Brazil	Standard Contractual Clauses (aligned with LGPD equivalence review)	Q4 2025

Note: This table must be reconciled quarterly against the current list of European Commission adequacy decisions, as such determinations may be revised, suspended, or withdrawn.

Appendix F — Consent Form Template (Marketing Communications)

Consent to Receive Marketing Communications

I consent to [Company Name] processing my personal data (name, email address, purchase history) for the purpose of sending marketing communications about products and services that may be of interest to me, via: ☐ Email ☐ SMS ☐ Phone.

I understand that I can withdraw this consent at any time by clicking "unsubscribe" in any communication, or by contacting privacy@company.example.

This consent will remain valid for 3 years from the date given, or until withdrawn, whichever is earlier.

☐ I consent Date: _____ Signature/Digital confirmation: _____

Appendix G — Sample DPIA Extract (Redacted Illustrative Example)

Project: Customer Behavioral Analytics Module **Risk Identified:** Profiling of customer purchasing patterns to generate personalized offers could produce discriminatory pricing outcomes if not monitored. **Likelihood:** Medium **Severity:** Medium-High **Mitigation:** (1) Human review of pricing model outputs on a monthly basis; (2) Exclusion of Special Category

Data and proxies thereof from model features; (3) Customer-facing opt-out mechanism for personalized pricing; (4) Quarterly bias audit conducted by an independent internal team. **Residual Risk After Mitigation:** Low **DPO Recommendation:** Approved for deployment subject to quarterly bias audit reporting to the DPO.

Appendix H — Glossary of Regulatory Terms

- **Adequacy Decision:** A determination by the European Commission that a non-EEA country provides an adequate level of data protection, permitting free data flow without additional safeguards.
- **Anonymization:** Irreversible process rendering a data subject no longer identifiable, placing the data outside the scope of GDPR.
- **Binding Corporate Rules (BCRs):** Internal rules adopted by a multinational group of companies to allow intra-group international transfers of personal data.
- **Legitimate Interest Assessment (LIA):** A three-part test (purpose, necessity, balancing) used to justify processing under the legitimate interests lawful basis.
- **Privacy by Design:** An approach requiring data protection to be embedded into the design of systems and business practices from the outset, rather than added afterward.
- **Pseudonymization:** Processing personal data such that it can no longer be attributed to a specific data subject without additional information kept separately.
- **Supervisory Authority:** The independent public authority responsible for monitoring GDPR compliance within a Member State (e.g., the ICO in the UK, the CNIL in France).

Appendix I — Document Revision History

Version	Date	Summary of Changes	Approved By
1.0	15 Jan 2024	Initial policy issuance	DPO
1.1	3 Jun 2024	Added Section 14 (Cookie Policy) following website redesign	DPO
1.2	20 Nov 2024	Updated retention schedule (Appendix A) per Finance review	DPO / Finance Director
2.0	1 Mar 2026	Full policy review; added employee monitoring, children's data, and DPIA appendix sections	DPO / Legal Counsel

This document is a synthetic artifact generated for research and system evaluation purposes. It does not represent an actual corporate policy and contains no real personal or organizational data.